Evidence list

Business: Example Electrical Ltd Date: 23 October 2026

Evidence folder: Folder “Security” on the office server and the paper folder in the office

27 pieces of evidence a questionnaire typically asks for. 3 are on file or produced by this toolkit and carry an attachment number. 7 measures are in place by your answers; their evidence gets a number once it is filed. The rest carry the date from the action plan. A customer reads this list as the table of attachments of the self-declaration.

Available: attachments

No.	Evidence	Proves	Status	Where
Att. 1	Security self-declaration (D1)	All sections	produced by the toolkit	Folder “Security” on the office server and the paper folder in the office
Att. 2	Responsibilities: responsible person, deputy, contact	Section A	produced by the toolkit	Folder “Security” on the office server and the paper folder in the office
Att. 3	Action plan with target dates (D2)	Every “partly” and “not yet”	produced by the toolkit	Folder “Security” on the office server and the paper folder in the office

In place: file the evidence

These measures are in place by your answers. Put the evidence in the evidence folder, enter in the workbook where it is, and only then give it the next attachment number.

Evidence	Proves
Screenshot of the user list in the admin console, one account per person.	C1 · Does every person have their own account, with no shared logins?

Evidence	Proves
Screenshot of the setting per account or the administrator report.	C2 · Is multi-factor authentication switched on for every email account?
Update settings; monthly check note.	E1 · Are updates installed automatically within days on every computer, phone and server?
Screenshot of the protection and encryption status per device.	E3 · Is protective software active on every computer, and are laptops and phones encrypted?
Clause in the contracts or signed addenda.	G2 · Are staff bound to confidentiality in writing, for example in the employment contract?
Written rule, signed and dated.	G3 · Is there a rule for payments: every change of bank details and every unusual payment request is confirmed by a call-back to a known number?
Rule; confirmation template.	I1 · At the end of a contract, are the customer's data returned or deleted, and can you confirm it in writing?

Missing: with target date

Evidence	Proves	Due	How it comes about
Emergency card, printed and posted (D3)	Sections D and F	22 November 2026	Fill in the yellow fields, print, post, date.
Signed rules with date; acknowledgement list.	B1 · Are there written security rules for staff: devices, passwords, email, what to report?	21 January 2027	Write the security rules for staff on one or two pages: devices, passwords, email, payments, what to report and to whom. The management signs them, every person acknowledges them.
Screenshots or administrator report per system.	C3 · Is it switched on for remote access, administrator accounts, cloud consoles and online banking?	22 November 2026	Switch on multi-factor authentication for remote access (VPN, remote desktop), every administrator account, the cloud consoles and online banking.
Account list; offboarding checklist with dates.	C4 · Are the accounts of leavers disabled the same day, from a list of all accounts?	21 January 2027	Write the list of all accounts per person and add an offboarding checklist that disables them on the day of leaving. Test it on the next departure.
Account list showing daily and administrator accounts.	C5 · Is daily work done without administrator rights, with separate accounts for administration?	21 January 2027	Remove administrator rights from the daily accounts and create separate administrator accounts that are used only for administration.

Evidence	Proves	Due	How it comes about
Written rule; password manager rolled out (licence or screenshot).	C6 · Is there a password rule: one long password per account in a password manager, changed only on suspicion?	21 January 2027	Roll out a password manager for everyone and write the rule: one long password per account, fifteen characters or more where there is no second factor, changed only on suspicion, checked against breach lists.
Backup settings and schedule; where the copy out of reach is.	D1 · Is all business data backed up automatically every day, with one copy offline or otherwise out of reach of an attacker?	22 November 2026	Set up daily automatic backups of all business data with one copy out of reach of an attacker: offline, on a rotated disk, or in a cloud copy that cannot be deleted from the office.
Restore test record with date and duration.	D2 · Has a restore from backup been tested in the last twelve months, with the time it took written down?	22 November 2026	Restore one folder from the backup, stop the time, write down date, duration and result. Repeat once a year.
Device list with dates.	E2 · Is there a list of all devices, and is every device and program still supported by its manufacturer?	21 January 2027	Write the device list: device, user, system, supported until. Replace or take off the network every device whose system is no longer supported.
Router settings and the date of the check.	E5 · Is the router or firewall kept current, with its own administrator password changed, remote administration switched off and a separate guest network for visitors?	21 January 2027	Update the router or firewall, change its administrator password, switch off remote administration, separate the guest network from the business network.
Emergency card; the names in the rules.	F2 · Is it known who checks after an incident whether personal data is affected, and who reports to the data protection authority within 72 hours?	22 November 2026	Name who checks after an incident whether personal data is affected and who reports to the data protection authority within 72 hours of becoming aware. Put both on the emergency card.
Incident log, even if still empty, with a date.	F4 · Are incidents written down: what happened, how, what was missing, what was changed?	21 January 2027	Start an incident log: one page per incident with what happened, how, what was missing, what was changed, who checked it.
Attendance list with date and contents.	G1 · Have staff been briefed on phishing, passwords and the reporting channel in the last twelve months, with an attendance record?	21 January 2027	Hold a half-hour briefing on phishing, passwords, payments and the reporting channel. Keep the attendance list with date and contents. Repeat once a year and for every new hire.

Evidence	Proves	Due	How it comes about
Provider list with country and purpose.	H1 · Is there a list of the providers that handle your data or your customers' data: email, file storage, accounting, website hosting, with country and purpose?	21 January 2027	Write the list of providers that handle your data or your customers' data: provider, country, purpose, contract, contact.
Agreements filed; console settings.	H2 · Do you have data processing agreements with those providers, and are their security settings (multi-factor authentication, two administrators) switched on?	21 January 2027	Obtain the data processing agreement from every provider that processes personal data on your behalf, and switch on multi-factor authentication and set up a second administrator account for a second person in every provider console.
Rule; template email.	H3 · Would you inform the customer before changing a provider that handles their data?	21 April 2027	Add to the rules that the customer is informed before a provider that handles their data is changed; keep a template email.

Not applicable

- Published contact and support statement. (E4 · If you supply software or devices: is there a contact for reporting vulnerabilities, and a support period for your products?)

Generated with the Scutoria Security Evidence Toolkit from the answers of the business. Whether a customer accepts a piece of evidence is the customer's decision. Source-based. No legal advice.